PROJECT | SOX / GRC

Building a SOX risk assessment and RCM for a card-payments fintech

Scoping, risk scoring, 16 key controls, testing results and deficiency evaluation, end to end.

THE SCENARIO

NovaPay prepares for its first SOX 404(b) audit

- Fictional U.S. card-payments fintech, newly public.
- In scope: card payments, disputes and chargebacks, merchant payouts, financial close, and the ITGCs behind them.
- Frameworks: COSO 2013, PCAOB AS 2201, ASC 326 (CECL) for chargeback reserves, ASC 606 for fees.

STEP 1 | RISK ASSESSMENT

12 risks scored on likelihood × impact

	I1	I2	I3	I4	I5
L5					
L4				1	
L3			2	2	4
L2				1	2
L1					

L = likelihood, I = impact (1–5). 5 high, 7 medium. Top risks: settlement completeness, CECL reserve assumptions, unreviewed manual JEs.

STEP 2 | RISK & CONTROL MATRIX

16 controls, mapped to risk and assertion

15
key controls

3
fully automated (ITAC / system block)

11
detective controls

4 of 5
COSO components covered

Each control lists nature, frequency, COSO component and the FY2025 test approach.

STEP 3 | TESTING RESULTS

13 of 16 effective (81%)

CONTROL	EXCEPTION	SEVERITY
Clearing account rec	Aged items not escalated	Deficiency
Merchant bank changes	2/25 missing call-back	Significant
Manual JE approval	17 self-approved JEs	Significant

No material weakness after considering compensating controls and aggregation.

TAKEAWAY

Good SOX work is risk-first, not checklist-first

Start from what could misstate the financials, then design the fewest controls that cover it, then prove they work.

The full workbook (risk register, RCM, heat map, deficiency log) is linked in the post.